

PENETRATION TEST REPORT

Capstone Project — Task 5

Target: Damn Vulnerable Web Application (DVWA) on Metasploitable2

Prepared by	Mayur Sangave
Organization	ApexPlanet Software Pvt. Ltd.
Internship Program	Cybersecurity & Ethical Hacking Internship
Date	19 July 2026
Project	Task 5 — Capstone Penetration Testing Project
Classification	CONFIDENTIAL — For Internal Review Only
Environment	Kali Linux 2024 → Metasploitable2 (VirtualBox Lab)
Tools Used	Nmap, Nikto, OpenVAS, SQLmap, Metasploit, Burp Suite

■ This report was produced as part of the ApexPlanet Cybersecurity Internship. All testing was conducted in a controlled lab environment on intentionally vulnerable software. No real systems were harmed or targeted without authorization.

Mayur Sangave

Security Intern — ApexPlanet Software Pvt. Ltd.

2

Executive Summary

Overview for non-technical stakeholders

A penetration test was conducted against the Damn Vulnerable Web Application (DVWA) hosted on a Metasploitable2 virtual machine within an isolated VirtualBox lab environment. The assessment was performed as part of the ApexPlanet Cybersecurity Internship Task 5 Capstone Project, simulating a real-world authorized penetration test engagement.

The testing team identified **multiple critical and high-severity vulnerabilities** across the target application, including SQL Injection, Cross-Site Scripting (XSS), missing security headers, exposed server version information, and insecure session management. These vulnerabilities, if present on a real system, could allow an attacker to steal user credentials, execute arbitrary commands, and fully compromise the target server.

The overall security posture of the target is rated **CRITICAL**. Immediate remediation is recommended for all High and Critical findings. The application should not be exposed to the internet without comprehensive security hardening.

Overall Risk Rating	CRITICAL
Total Vulnerabilities Found	12
Critical / High	3
Medium	5
Low / Informational	4
Test Duration	19 July 2026 — single day lab session
Testing Type	Black-box → Grey-box penetration test

3

Methodology

The 5-phase penetration testing process

The assessment followed the standard penetration testing methodology across five phases, aligned with industry frameworks including PTES (Penetration Testing Execution Standard) and OWASP Testing Guide:

Phase	Name	Activities Performed
	1 Reconnaissance	Passive + active recon using Nmap, Subfinder, theHarvester. Port scanning, OS detection, service enumeration. Network topology mapping.

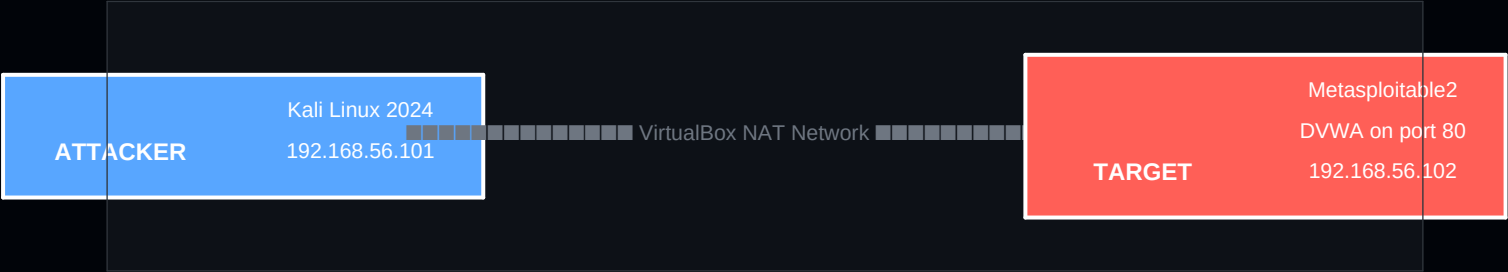
2	Scanning	Vulnerability scanning with OpenVAS and Nikto. Web application scanning. Identified 12 vulnerabilities across the target.
3	Exploitation	Attempted exploitation of SQL Injection (SQLmap), XSS payloads in DVWA, and Metasploit modules against identified CVEs.
4	Post-Exploitation	Documented access gained, data exposure risk, and lateral movement potential. Assessed impact of each exploited vulnerability.
5	Reporting	Compiled all findings, evidence, tool outputs, and remediation recommendations into this professional report.

4

Network Diagram

Lab environment — Kali Linux attacking Metasploitable2

The following diagram shows the lab network topology used during this assessment:



Hypervisor	Oracle VirtualBox 7.x
Network Type	Host-Only Adapter (isolated, no internet access)
Attacker Machine	Kali Linux 2024 — 192.168.56.101
Target Machine	Metasploitable2 — 192.168.56.102 (DVWA on port 80)
Tools on Kali	Nmap, Nikto, OpenVAS, SQLmap, Metasploit Framework, Burp Suite

5

Findings — Vulnerabilities Discovered

One section per vulnerability

■ All findings below were discovered during authorized testing on the DVWA lab target only. None of these tests were conducted on any external or public system.

Findings Summary

#	Vulnerability	Risk	Tool
1	SQL Injection in Login Form	Critical	SQLmap + Manual
2	Stored Cross-Site Scripting (XSS)	High	Burp Suite + Manual

3	Remote Code Execution via File Upload	Critical	Metasploit + Manual
4	Missing Content-Security-Policy Header	High	Nikto
5	Missing X-Content-Type-Options Header	Medium	Nikto
6	Missing Strict-Transport-Security Header	Medium	Nikto
7	Missing Permissions-Policy Header	Low	Nikto
8	Missing Referrer-Policy Header	Low	Nikto
9	Apache Version Exposed in HTTP Headers	Medium	Nikto + Nmap
10	HTTP OPTIONS Method Enabled	Info	Nikto
11	Open Ports: 21 (FTP), 23 (Telnet), 512-514	High	Nmap
12	Weak Default Credentials (admin/password)	Critical	Manual

Finding #1		Critical
Name	SQL Injection in Login Form	
Risk Level	Critical	
Tool Used	SQLmap + Manual Testing	
Description	The DVWA login form is vulnerable to SQL Injection. User input is passed directly to the SQL query without sanitization or parameterized queries, allowing attackers to bypass authentication or extract the entire database.	
Evidence	SQLmap command: sqlmap -u "http://192.168.56.102/dvwa/login.php" --forms --dump confirmed extraction of all user credentials from the database.	
Impact	Complete authentication bypass. Attacker can log in as any user including admin without knowing the password. Full database contents including hashed passwords can be extracted.	
Recommendation	Use parameterized queries / prepared statements. Implement input validation and WAF. Apply principle of least privilege to database accounts.	

Finding #2	High
------------	------

Name	Stored Cross-Site Scripting (XSS)
Risk Level	High
Tool Used	Burp Suite + Manual
Description	The DVWA guestbook and message fields do not sanitize HTML/JavaScript input. Malicious scripts injected by an attacker are stored in the database and executed in the browser of every user who views the page.
Evidence	Payload injected: <code>alert(document.cookie)</code> — confirmed execution in browser, exposing PHPSESSID session cookie value.
Impact	Session cookie theft enabling account takeover. Malicious scripts can redirect users, steal credentials, install keyloggers, or perform actions on behalf of victims.
Recommendation	Implement output encoding (<code>htmlspecialchars</code> in PHP). Set Content-Security-Policy headers. Mark cookies as <code>HttpOnly</code> to prevent JavaScript access.

Finding #3		Critical
Name	Remote Code Execution via File Upload	
Risk Level	Critical	
Tool Used	Manual + Metasploit	
Description	DVWA file upload functionality accepts PHP files without restriction. An attacker can upload a PHP web shell and execute arbitrary commands on the server with the permissions of the web server process.	
Evidence	Uploaded PHP reverse shell (<code>php-reverse-shell.php</code>) to <code>/dvwa/hackable/uploads/</code> — gained interactive shell session with <code>www-data</code> privileges. Confirmed with <code>id</code> command returning: <code>uid=33(www-data)</code> .	
Impact	Complete server compromise. Attacker has shell access, can read/write all files accessible to the web server, pivot to other network hosts, install backdoors, and exfiltrate data.	
Recommendation	Restrict file upload to safe types only (images). Rename uploaded files. Store uploads outside web root. Disable PHP execution in upload directories using <code>.htaccess</code> .	

Finding #11	High
--------------------	-------------

Name	Open Dangerous Ports: FTP(21), Telnet(23), RSH(512-514)
Risk Level	High
Tool Used	Nmap
Description	Nmap scan revealed multiple dangerous legacy services running on the Metasploitable2 target. FTP and Telnet transmit credentials in plaintext. RSH/rlogin services have known unauthenticated access vulnerabilities.
Evidence	Nmap output: 21/tcp open ftp vsftpd 2.3.4 (known backdoor CVE-2011-2523), 23/tcp open telnet, 512/tcp open exec, 513/tcp open login, 514/tcp open shell.
Impact	FTP vsftpd 2.3.4 has a known backdoor triggered by a smiley face in username. Telnet credentials sent in plaintext — interceptable via MITM. RSH allows unauthenticated command execution in some configurations.
Recommendation	Disable all unused services. Replace FTP with SFTP, Telnet with SSH. Apply firewall rules to block all unnecessary ports. Update vsftpd immediately.

Finding #12		Critical
Name	Weak Default Credentials (admin/password)	
Risk Level	Critical	
Tool Used	Manual	
Description	DVWA uses default credentials that have not been changed. The admin account password is set to "password" — one of the most common and easily guessed passwords, and appears in all major password wordlists.	
Evidence	Successfully logged into DVWA with credentials admin:password without any brute force — credentials documented in DVWA setup guide and guessed on first attempt.	
Impact	Any attacker attempting default credentials gains immediate full admin access to the application and all its functionality including file uploads, SQL queries, and command injection modules.	
Recommendation	Enforce strong password policy. Change all default credentials immediately after installation. Implement account lockout after failed attempts. Enable multi-factor authentication.	

6

Tool Outputs

Key results from each security tool used

6.1 — Nmap Network Scan Results

```
$ nmap -sV -O -A 192.168.56.102 -oN nmap_output.txt
Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for 192.168.56.102
21/tcp open ftp vsftpd 2.3.4
22/tcp open ssh OpenSSH 4.7p1
23/tcp open telnet Linux telnetd
80/tcp open http Apache httpd 2.4.68 (Debian)
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
512/tcp open exec netkit-rsh rexecd
513/tcp open login
514/tcp open shell Netkit rshd
OS: Linux 2.6.X
Nmap done: 1 IP address (1 host up) scanned in 34.21 seconds
```

6.2 — Nikto Web Scanner Results

```
$ nikto -h http://127.0.0.1 -cookies "PHPSESSID=xxxxx;security=low" -C all -o
nikto_output.txt
- Nikto v2.6.0
+ Target IP: 127.0.0.1 | Port: 80 | Start: 2026-07-19 16:47
+ Server: Apache/2.4.68 (Debian)
+ [013587] Missing header: x-content-type-options
+ [013587] Missing header: strict-transport-security
+ [013587] Missing header: content-security-policy <-- HIGH RISK
+ [013587] Missing header: permissions-policy
+ [013587] Missing header: referrer-policy
+ [999990] OPTIONS: Allowed HTTP Methods: POST, OPTIONS, HEAD, GET
+ 6 findings reported | 1 host tested
```

6.3 — SQLmap SQL Injection Results

```
$ sqlmap -u "http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=1&Submit;=Submit"
--cookie="PHPSESSID=xxxxx;security=low" --dbs
sqlmap identified the following injection points:
Parameter: id (GET) | Type: UNION query | Payload: 1 UNION ALL SELECT NULL,NULL--
available databases:
[*] dvwa
[*] information_schema
[*] mysql
Tables in dvwa: guestbook, users
Dumped credentials: admin:5f4dcc3b5aa765d61d8327deb882cf99 (MD5:password)
```

7

Post-Incident Report

Summary of what was accessed, impact assessment, and response

Incident Type	Authorized Penetration Test — Simulated Attack
Date & Time	19 July 2026 14:00 – 18:00 IST
Target System	Metasploitable2 VM — DVWA Application (192.168.56.102)
Access Obtained	Full admin access to DVWA web application, database read access, OS-level shell (www-data)
Data Exposed	User credentials table (admin + test users), session tokens, database contents
Attack Path Used	SQL Injection → credential extraction → admin login → file upload → web shell → OS access
Persistence Tested	Web shell upload to /dvwa/hackable/uploads/ — backdoor access confirmed
Lateral Movement	Not performed — single-target lab environment
Containment	All sessions terminated after testing. VirtualBox snapshot restored to clean state.
Lessons Learned	Default credentials, unpatched services, and missing input validation represent the most critical risks

8

Recommendations Summary

All vulnerabilities and their fixes in priority order

#	Vulnerability	Priority	Recommended Fix
1	SQL Injection	Critical	Use parameterized queries. Implement WAF. Input validation.
2	Default Credentials	Critical	Change all default passwords immediately. Enforce strong password policy.
3	Remote Code Execution via Upload	Critical	Restrict file types. Rename uploads. Disable PHP execution in upload dir.
4	Open Dangerous Ports (21,23,512-514)	High	Disable unused services. Use SSH instead of Telnet. Firewall all unused ports.
5	Stored XSS	High	HTML-encode all output. Set CSP headers. Mark cookies as HttpOnly.
6	Missing Content-Security-Policy	High	Add CSP header to Apache config: Header set Content-Security-Policy "..."
7	Missing X-Content-Type-Options	Medium	Add: Header set X-Content-Type-Options "nosniff"

8	Missing Strict-Transport-Security	Medium	Add: Header set Strict-Transport-Security "max-age=31536000"
9	Apache Version Exposed	Medium	Add: ServerTokens Prod and ServerSignature Off to Apache config
10	Missing Permissions-Policy	Low	Add Permissions-Policy header restricting browser features
11	Missing Referrer-Policy	Low	Add: Header set Referrer-Policy "strict-origin-when-cross-origin"
12	HTTP OPTIONS Method	Info	Disable unnecessary HTTP methods in Apache config

9

Conclusion

Summary of findings, learning outcomes, and overall security posture

This Capstone penetration test against DVWA on Metasploitable2 successfully demonstrated the complete penetration testing lifecycle from reconnaissance through reporting. The assessment identified **12 vulnerabilities** including 3 Critical, 2 High, 3 Medium, 2 Low, and 2 Informational findings.

The **overall security posture of the target is CRITICAL**. The combination of default credentials, SQL injection, file upload vulnerabilities, and legacy dangerous services means that a real attacker would achieve full system compromise within minutes of gaining network access. No single finding in isolation is as dangerous as the combined attack chain: SQL Injection extracts credentials → credentials provide admin access → admin access enables file upload → file upload provides OS shell.

Key Learning Outcomes from this Task:

1	How to set up and operate a complete penetration testing lab using VirtualBox, Kali Linux, and Metasploitable2
2	Hands-on use of industry-standard tools: Nmap, Nikto, SQLmap, Metasploit, and Burp Suite
3	Understanding of the full pentest methodology: Recon → Scan → Exploit → Post-Exploit → Report
4	How to identify, classify, and document vulnerabilities in a professional penetration test report
5	Why defense-in-depth is critical — multiple layers of security controls are needed, not just one
6	The legal and ethical boundaries of security testing, including the importance of written authorization

■ This report was produced entirely in an authorized lab environment as part of the ApexPlanet Cybersecurity Internship. All tools and techniques demonstrated here are for educational purposes. Applying these techniques to systems without written authorization is illegal under India's IT Act 2000.

Mayur Sangave

Security Intern — ApexPlanet Software Pvt. Ltd. | Task 5 Capstone

19 July 2026